

Introduction to IT Security Management

“Good IT Security is often based around standards”

Module 1 Unit 1

Introduction to IT Management and IT Security Management

What is IT Management?

- An **IT environment** consists of a multitude of hardware, network and software components.
- An **IT infrastructure** can be on premises, in the cloud or on a hybrid platform that integrates both.

What is IT Management?

IT managers monitor and govern IT systems to ensure they're always available and function reliably.

- Determining business requirements for IT systems
- Managing IT budgets and costs
- Monitoring safety and compliance
- Controlling system and network security
- Implementing new software, hardware and data systems
- Providing technical or help desk support

IT Security Management - ITSM

- **IT security management** refers to the **monitoring** and **administration** of an organization's information technology systems that are used to secure their information and data
- **IT security management** intends to guarantee the Confidentiality, Integrity, and Availability of an organization's data, information and IT services

IT Security Management Sub-Processes

- **Designing security controls:** To guarantee the CIA of an organization's data
- **Security testing:** All security mechanisms are subjected to regular testing
- **Managing security incidents:** To identify and fight intrusions and attacks and to minimize damages incurred
- **Security review:** To review whether the safety measures and processes are still in accordance with risk perceptions

IT Security Management Roles and Position

The Chief Information Officer (CIO)

- Determine IT strategies and goals for the business and ensure they're implemented
- Many CIOs believe their roles will evolve in the next two to three years
- Implement meaningful digital change through the creation of new tools, solutions and business models

The Chief Information Security Officer (CISO)

- A CISO is a senior-level executive who oversees an organization's information, cyber, and technology security
- **CIO vs CISO**
 - CIOs job are **generalists**
 - CISOs job are more on **focused on security**

Other Related Positions

Security Administrator

- Responsible for the day-to-day management of security technology systems
- They install, administer, and troubleshoot an organization's security solutions, ensuring that the infrastructure is protected against unauthorized access or compromise

Other Emerging Positions

- **Cloud Security Manager:** reflects the shift towards cloud-based infrastructure
- **Threat Intelligence Manager:** focusing on proactive identification and mitigation of cyber threats

Module 1 Unit 2

Cybersecurity

Cybersecurity

- Cybersecurity is about studying and protecting computer systems from adversaries who attempt to use the system in a way that it wasn't meant to be used
 - Where “computer systems” include many kinds of networked — or non-networked — devices, from smartphones to traffic lights

Scale of Cyber Threats

- In 2019, 7.9B records have been exposed by data breaches in the first nine months.
- A cyberattack could trigger a serious financial crisis
 - *medical services, retailers and public entities*
- Cooperation on cybersecurity has been hampered, fragmented, and often limited to the smallest circles of trust

Scale of Cyber Threats: Financial Sector

- Still unclear who is responsible for protecting the system against cyberattacks
- Disruptive and destructive attacks has been increasing
- Financial services community does not lack resources or the ability to implement technical solutions.

Cybersecurity Culture

- refers to the knowledge, beliefs, perceptions, attitudes, assumptions, norms and values of people regarding cybersecurity and how they manifest themselves in people's behavior with information technologies
- align with the organization's approach to cyber security, manifesting in cyber security conscious behaviors

A Good Cybersecurity Culture

- organizational determinants of culture
- individual determinants of culture

Need for CSC

- the development of a CSC achieves a change in mindset, fosters security awareness and risk perception and maintains a close organizational culture, rather than attempting to coerce secure behavior
- a CSC needs to be embedded in the organizational culture
- can be difficult to identify, build, and quantify versus *safety culture*

Building a CSC: Reminders

- Culture extends beyond awareness to include the shaping of beliefs, norms, values
- A similar goal can be said for cybersecurity: every employee must act in ways that keep the organization cybersecure

Organizational Cybersecurity Culture (OCC)

To build a model of cybersecurity culture, let us examine three concepts:

- 1. organizational culture,**
- 2. nation culture and**
- 3. information security culture**

1. Organizational Culture

Four types of organizational culture based on the orientation of the values and beliefs:

1. The **support** orientation
2. The **innovation** orientation
3. The **rules** orientation
4. The **goal** orientation

2. National Culture

- Focuses on a cross-cultural perspective and impacts how employees comply with authority and follow organizational rules and policies
- The most accepted taxonomy of national culture, by Hofstede, includes concepts such as “individualism vs. collectivism,” “long-term vs. short-term orientation” and “indulgence vs. restraint”

3. Information Culture

- As a subculture of an organization's culture, it has been defined as:

“attitudes, assumptions, beliefs, values and knowledge that employees / stakeholders use to interact with the organization's systems and procedures at any point in time. The interaction results in acceptable or unacceptable behavior (i.e. incidents) evident in artifacts and creations that become part of the way things are done in the organization to protect its information assets. This information security culture changes over time”.

Myths about Cybersecurity

- **Myth 1: My business is too small to worry about cyber attacks**
“Maybe your data isn’t important outside the organization, but it could be devastating if somebody scrambles it all”
- **Myth 2: As long as I change my password often**
“Focus on complexity of the password, not frequency of resets,”
predictable passwords that were easily remembered
- **Myth 3: Policy will protect us**
“education and training are essential”

Myths about Cybersecurity

- **Myth 4: The bad guys are only on the Internet**

“There are many high-profile examples of cybersecurity attacks that originated from inside the business”

- **Myth 5: I own my social media data**

Social media data has also been used in other ways. Con artists have stolen photos of kids to use in fraudulent GoFundMe campaigns

- **Myth 6: My work computer is my computer**

If a laptop is breached as part of increasingly-commonplace corporate cyber events, that personal content can be stolen and used for nefarious purposes, e.g. extortion

Additional: Myths about Cybersecurity

- Free Wi-Fi is safe
- Antivirus is enough to keep me safe
- Cybersecurity is the IT Department's job
- Hackers only target big companies

Module 1 Unit 3

Computer Emergency Response Team (CERT)

What is CERT?

- A Computer Emergency Response Team (CERT) is a group of information security experts responsible for the protection against, detection of and response to an organization's cybersecurity incidents
- Conduct ongoing public awareness campaigns and engage in research aimed at improving security systems

Importance of CERT

A **CERT** is important for several reasons, primarily related to cybersecurity and the protection of digital infrastructures:

1. Incident Response and Mitigation
2. Proactive Security Monitoring
3. Coordination of Cybersecurity Efforts
4. Recovery and Restoration
5. Training and Awareness
6. Vulnerability Assessment and Management
7. Research and Threat Intelligence Sharing
8. Policy and Guideline Development

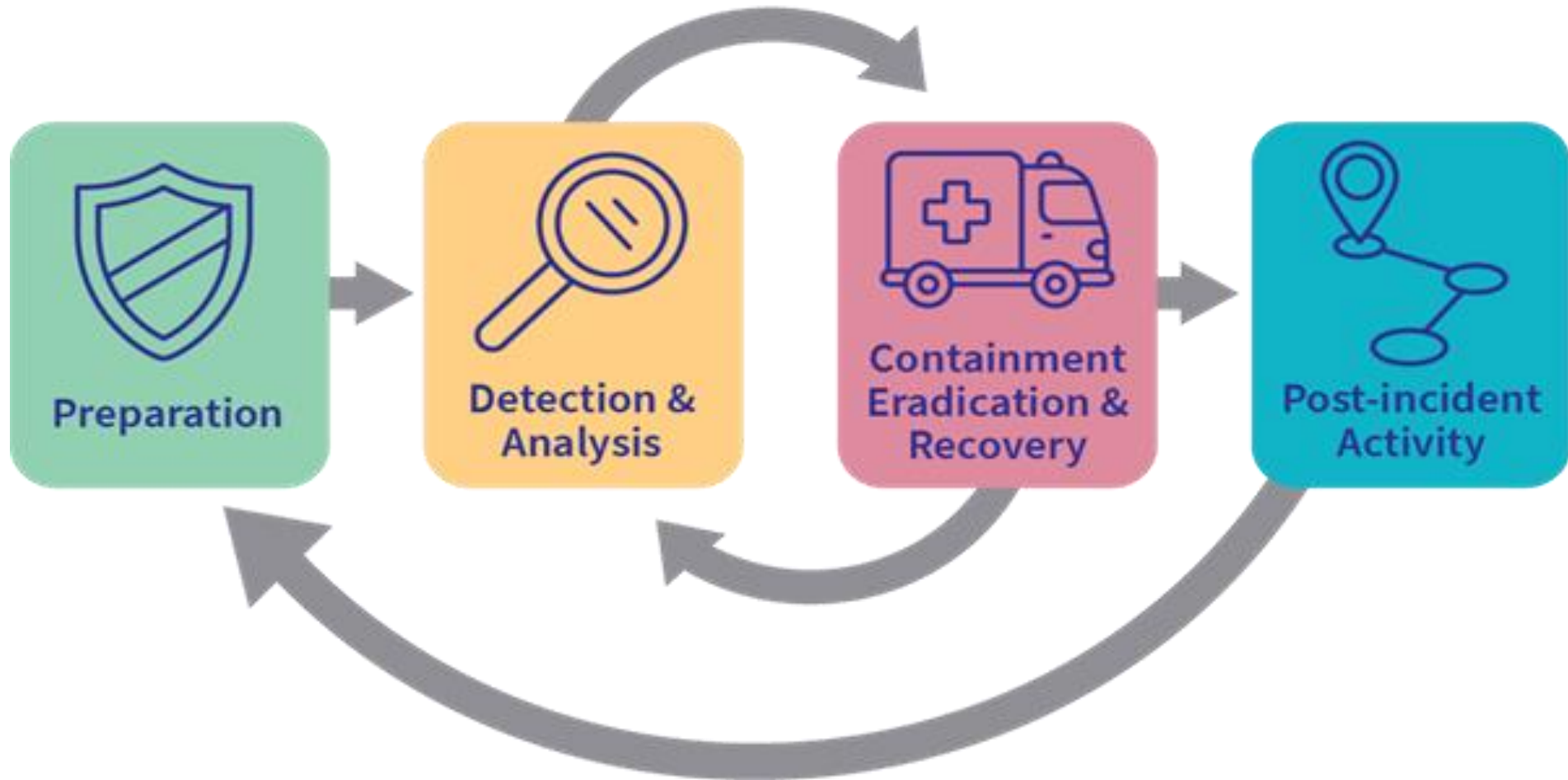
CERT Coordination Center

- SEI (Software Engineering Institute) of Carnegie Mellon University(Pittsburgh, Pennsylvania) established the Computer Emergency Response Team (CERT) Coordination Center in 1988
- Its mission is to respond to security emergencies on the Internet, serve as a focal point for reporting and resolving security vulnerabilities, serve as a model to help others establish incident response teams, and raise awareness of security issues.

NIST

- National Institute of Standards and Technology (NIST) - developed its own incident response model
- The NIST model uses the terms "protect, detect and respond"
- The SP-800-61 (Cyber Incident Response Cycle)

Cyber Incident Response Cycle



Protect, Detect, and Respond Model

Protect

- Making sure that an organization implements the measures and precautions necessary to secure its computers before any problems occur.
- CERTs often employ a variety of protective measures and strategies to better protect systems.

Protect, Detect, and Respond Model

Protect

- Create an organizational incident response plan.
- Perform risk assessments or analysis.
- Create an up-to-date asset inventory management
- Implement vulnerability scanning tools and intrusion detection systems (IDS)
- Provide security awareness training for all employees.

Protect, Detect, and Respond Model

Detect

- Recognizing security incidents by using a variety of technology
- To determine if a system isn't working properly, CERTs generally work on determining how the network typically works
- They document every part of a network and establish baselines or points of reference to compare each individual part.

Protect, Detect, and Respond Model

Detect

- What applications are always in use?
- What does normal network traffic look like?
- Which network protocols are in use?
- Which network protocols should never appear on the network?
- What are normal bandwidth utilization patterns, including volume and direction?
- What devices are supposed to be attached to the network?
- Who are the system and data owners for these attached hosts and devices?

Protect, Detect, and Respond Model

Detect

- System management requires that every part of a network must be documented and baselined. This can be accomplished with:
 - A software asset management (SAM) program
 - An application management and security program
 - Change, configuration and patch management programs
 - A bandwidth utilization baseline and routine bandwidth checks against the baseline
 - Network flow baselines and continuous monitoring

Protect, Detect, and Respond Model

Respond

- CERTs can begin **to respond** to the incident
- **Analyzing** the incident to understand what's occurring and why
- **Create** a strategy to prevent the incident from causing lasting damage and retain control over systems
- **Execute** it to help restore operations as quickly as possible.